

Data Privacy Laws and Regulations

GRC104 - Compliance Frameworks and Legal Requirements



International Cybersecurity and Digital Forensics Academy

Week 17: November 3-9, 2025

Introduction to Data Privacy

Data privacy refers to the protection of personal information and the right of individuals to control how their data is collected, used, stored, and shared. It encompasses the legal frameworks, policies, and practices that govern the handling of sensitive information.

Era	Focus	Key Developments
1970s-1990s	Basic data protection	First-generation privacy laws
2000s-2015	Digital privacy	Sector-specific regulations
2016-Present	Comprehensive protection	GDPR and global privacy laws
Future	Privacy by design	Embedded in technology development

Why Data Privacy Matters

Organizations collect unprecedented amounts of personal data in today's digital landscape. With global connectivity and emerging technologies like AI and IoT, privacy challenges continue to grow. Studies show that 87% of consumers will take their business elsewhere if they don't trust a company to handle their data responsibly.



Key Principles of Data Privacy

Transparency and Notice

Organizations must clearly inform individuals about how their data is collected, used, and shared through accessible privacy notices.

Purpose Limitation

Personal data should only be collected for specified, explicit, and legitimate purposes, and not processed in ways incompatible with those purposes.

Data Minimization

Only collect and retain the minimum amount of personal data necessary to fulfill the stated purpose.

Accuracy

Personal data must be kept accurate and up-to-date, with reasonable steps taken to correct or delete inaccurate information.

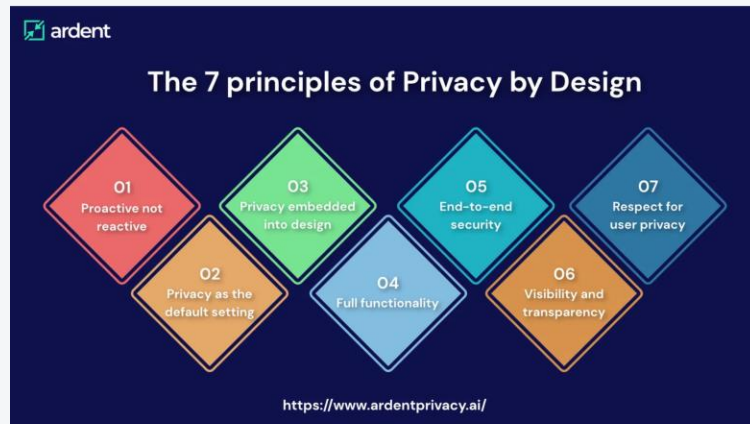
Storage Limitation

Data should not be kept longer than necessary for the purposes for which it was collected.

Integrity and Confidentiality

Appropriate security measures must be implemented to protect personal data against unauthorized access, accidental loss, or damage.

Accountability



Major Global Data Privacy Laws (Part 1)

European Union: GDPR

The General Data Protection Regulation (GDPR) is the world's most comprehensive data privacy law, effective since May 2018.

Territorial Scope:

Applies to organizations in the EU and those targeting EU residents

Key Provisions:

Legal basis required for processing, enhanced individual rights

Data Subject Rights: Access, rectification, erasure, portability

Penalties: Up to €20 million or 4% of global annual revenue

Key Difference: While GDPR is based on the principle that privacy is a fundamental right, CCPA focuses more on consumer protection and the right to control personal information as a consumer right.

California: CCPA/CPRA

The California Consumer Privacy Act (CCPA), enhanced by the California Privacy Rights Act (CPRA), establishes comprehensive privacy rights for California residents.

Applicability:

Businesses with \$25M+ revenue or handling data of 50,000+ consumers

Consumer Rights: Know, delete, opt-out, non-discrimination

Unique Feature: Private right of action for data breaches

Penalties: Up to \$7,500 per intentional violation

Major Global Data Privacy Laws (Part 2)

Brazil: Lei Geral de Proteção de Dados (LGPD)

The LGPD establishes a comprehensive framework for data protection in Brazil, drawing significant inspiration from the GDPR while maintaining unique elements tailored to the Brazilian context.

- 🌐 Extraterritorial scope similar to GDPR
- ⚖️ Ten legal bases for processing personal data
- 👤 Data subject rights closely mirror those in GDPR
- ⚖️ Penalties up to 2% of Brazilian revenue (capped at 50 million reais)

Other Significant Privacy Laws

- 🇨🇦 Canada's PIPEDA: Based on ten fair information principles
- 🇨🇳 China's PIPL: Strict data localization requirements
- 🇦🇺 Australia's Privacy Act: 13 Australian Privacy Principles
- 🇺🇸 US State Laws: Growing patchwork including Virginia, Colorado, Connecticut, Utah

Similarities between CCPA and GDPR

Focus Area	CCPA	GDPR
 User rights	Defined	Defined
 Consent to share data	Defined	Defined
 Revoke data from being processed	Defined	Defined
 Who does it apply to?	Defined	Defined
 Penalties for non-compliance	Defined	Defined
 Grounds for processing data	Defined	Defined
 Law enforcer	Defined	Defined

Industry-Specific Privacy Regulations

♥ Healthcare: HIPAA

The Health Insurance Portability and Accountability Act (HIPAA) establishes national standards to protect individuals' medical records and other personal health information.

- ✓ Covered Entities:
Healthcare providers, health plans, clearinghouses
- ✓ Key Rules:
Privacy Rule, Security Rule, Breach Notification Rule
- ✓ Penalties:
Up to \$1.5 million per violation category per year

Other Regulations	Sector	Key Requirements
COPPA	Children's Online Services	Parental consent for collecting data from children under 13
FERPA	Education	Protects privacy of student education records

🏛 Financial Services: GLBA

The Gramm-Leach-Bliley Act (GLBA) requires financial institutions to explain their information-sharing practices and safeguard sensitive customer data.

- ✓ Key Components:
Financial Privacy Rule, Safeguards Rule, Pretexting Provisions
- ✓ Applies to:
Banks, securities firms, insurance companies, and other financial service providers



Enforcement and Penalties

Regulatory Authorities

📍 European Data Protection Authorities (DPAs)

🏛️ Federal Trade Commission (FTC)

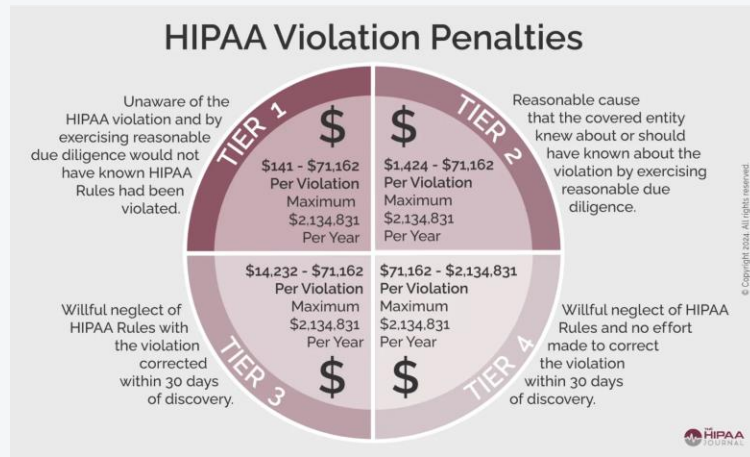
🏛️ Office for Civil Rights (OCR)

🏛️ State Attorneys General

🛡️ National Data Protection Authority (ANPD)

Penalties for Non-Compliance

Regulation	Maximum Financial Penalties
GDPR	€20 million or 4% of global annual revenue
CCPA/CPRA	\$7,500 per intentional violation
HIPAA	\$1.5 million per violation category per year
GLBA	\$100,000 per violation
LGPD	2% of Brazilian revenue (up to 50 million reais)



Notable Enforcement Actions

2023: Amazon fined €746 million by Luxembourg DPA

2024: Meta fined €1.2 billion for EU-US data transfers

2025: Major US healthcare provider penalized \$15 million

2025: Financial institution fined \$25 million for GLBA violations

Compliance Challenges

Cross-Border Data Transfers

Organizations must navigate complex mechanisms such as Standard Contractual Clauses, Binding Corporate Rules, adequacy decisions, and data localization requirements.

Vendor Management

Third-party relationships introduce substantial privacy risks requiring comprehensive due diligence, data processing agreements, and regular security assessments.

Evolving Regulations

The rapidly changing global privacy landscape requires organizations to continuously monitor and adapt to new requirements across multiple jurisdictions.

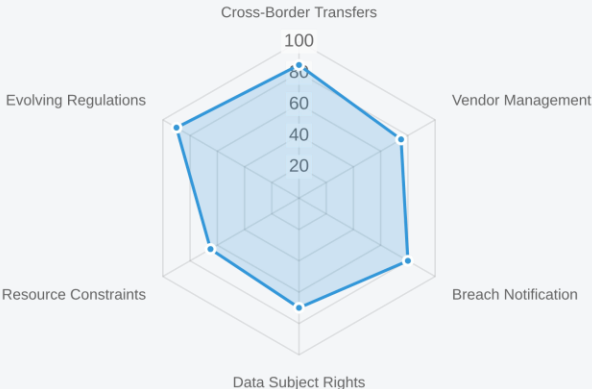
Data Subject Rights

Implementing processes to handle access, deletion, portability, and other requests in a timely manner across complex data ecosystems.

Breach Notification Requirements

Regulation	Timeline	Recipients
GDPR	72 hours	Supervisory authority, affected individuals
HIPAA	60 days	HHS, affected individuals, media (large breaches)
US State Laws	30-90 days	State AG, affected residents

Relative Complexity of Privacy Compliance Challenges



Best Practices for Compliance

Privacy by Design and Default

Privacy by Design represents a proactive approach to embedding privacy into the design and operation of IT systems, business practices, and physical infrastructure from the earliest stages of development.

- 🛡️ **Data Governance Framework:** Maintain comprehensive data inventory, classification system, and retention policies
- 📋 **Risk Management Approach:** Conduct regular Data Protection Impact Assessments (DPIAs) and prioritize high-risk processing activities
- 👤 **Access Controls:** Implement role-based access to limit data exposure based on legitimate need-to-know
- 🎓 **Privacy Training:** Regular education for all employees to create a privacy-aware culture

- ⚠️ **Incident Response:** Documented procedures for privacy breaches to reduce impact of incidents
- 🔍 **Vendor Management:** Due diligence and contractual safeguards to mitigate third-party risks
- 📄 **Privacy Notices:** Clear, accessible information practices to build trust and transparency
- ✅ **Regular Audits:** Systematic review of privacy controls to identify gaps proactively

Privacy Program Maturity Comparison



Future Trends in Data Privacy

Artificial Intelligence and Algorithmic Transparency

Increasing focus on explainable AI, algorithmic impact assessments, and regulations addressing automated decision-making.

Biometric Data Protection

Stricter regulations for facial recognition, voice data, and other biometric identifiers as their use becomes more widespread.

Internet of Things (IoT) Privacy

New frameworks addressing the unique challenges of ambient data collection in smart homes, cities, and connected devices.

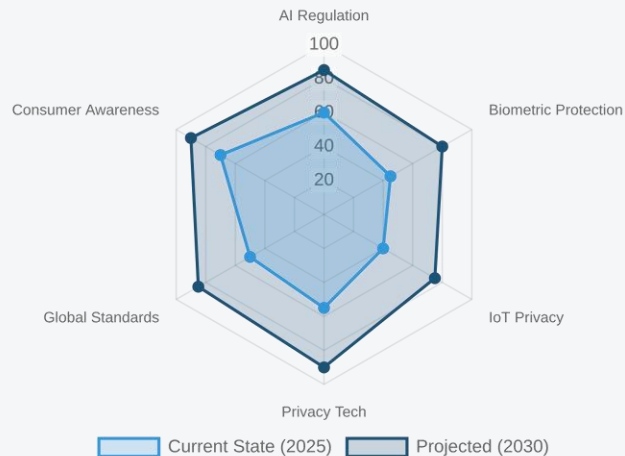
Privacy-Enhancing Technologies (PETs)

Growing adoption of homomorphic encryption, federated learning, differential privacy, and zero-knowledge proofs.

Global Harmonization

Movement toward more consistent international privacy standards to reduce compliance complexity for global organizations.

Privacy Trend Maturity Projection



Predictions for 2026 and Beyond

- ✓ Privacy becoming a core competitive differentiator
- ✓ Automated compliance tools reducing manual privacy workloads
- ✓ Privacy engineering emerging as a distinct professional discipline
- ✓ Increased integration between privacy, security, and data governance

Conclusion & Resources

Key Takeaways

- ✓ Data privacy has evolved from a niche legal concern to a fundamental business requirement
- ✓ Organizations need an integrated approach that embeds privacy into business processes
- ✓ Risk-based prioritization focuses resources on sensitive data and high-risk processing
- ✓ Cultural commitment to privacy must extend beyond legal or compliance departments
- ✓ Proactive stance anticipates regulatory changes rather than reacting to them

Recommended Resources

Resource Type	Recommendations
Regulatory Guidance	EDPB Guidelines, FTC Privacy Framework, NIST Privacy Framework
Industry Organizations	IAPP, Future of Privacy Forum
Training	IAPP Certifications (CIPP, CIPM, CIPT)